

FINAL TECHNICAL REPORT

Security Incident Response & Remediation

Classification:	Confidential	Response Type:	Live Incident Response
System:	Active Production Server	Status:	Remediated

1. Incident Overview

During a live analysis of an active production server, a potential security incident was identified involving **unauthorized access** and **exposed network services**. The investigation followed a live incident-response methodology — the system remained operational throughout to preserve forensic evidence and minimise service disruption.

Two primary threats were uncovered: an unsecured FTP service running on the host, and a rogue user account with full shell access. Both were promptly contained and eradicated.

2. Detected and Corrected Vulnerabilities

2.1 FTP Service Exposure (vsftpd)

The **vsftpd** FTP daemon was found active and listening on the host. FTP transmits credentials and data in plaintext, making it unsuitable for secure environments.

■ Risk Factors

- Potential for unauthorised file access or exfiltration
- Credentials interceptable via network sniffing
- Possible attacker entry point if misconfigured

✓ Actions Taken

- Stopped the service: `systemctl stop vsftpd`
- Disabled auto-start: `systemctl disable vsftpd`

2.2 Unauthorised User Account — "hacker"

A suspicious local account named **hacker** was discovered. The account possessed a valid login shell and a home directory, indicating it was created deliberately as a potential persistence or backdoor mechanism.

Attribute	Detail
-----------	--------

Login Shell	/bin/bash (full interactive access)
Home Directory	/home/hacker (present on disk)
Recorded Logins	None detected via last command

■ Risk Factors

- Potential persistence mechanism left by an attacker
- Backdoor enabling future unauthorised access

✓ Actions Taken

- Removed user and home directory: `sudo userdel -r hacker`
- Verified removal from `/etc/passwd`
- Confirmed `/home/hacker` no longer exists on disk

3. Containment, Eradication, and Recovery

Phase	Action	Outcome
Containment	Stopped vsftpd service	Service no longer accepting connections
Eradication	Disabled vsftpd auto-start	Service will not restart on reboot
Eradication	Removed hacker account and home dir	Account fully purged from system
Verification	<code>ps aux grep hacker</code>	No active malicious processes found
Verification	Checked cron directories for persistence	No scheduled malicious tasks detected
Verification	Reviewed login history (last)	No suspicious login sessions found
Recovery	System returned to normal operation	Secure state confirmed

4. Recommendations

1. Disable Unnecessary Services

Audit all running services and disable those not required for business operations. Minimising the attack surface reduces the likelihood of exploitation.

2. Replace FTP with SFTP

Migrate all file-transfer operations to SFTP (SSH File Transfer Protocol), which encrypts both credentials and data in transit.

3. Regular User Account Audits

Periodically review `/etc/passwd` and `/etc/shadow` to detect accounts that should not exist. Remove or lock any unused or suspicious accounts immediately.

4. Centralised Log Monitoring

Actively monitor `/var/log/auth.log` and `/var/log/syslog` for anomalous activity. Consider forwarding logs to a SIEM for real-time alerting.

5. Principle of Least Privilege

Ensure every account and service operates with only the minimum permissions required. Avoid granting root or sudo access unless strictly necessary.

6. Firewall Hardening

Implement host-based firewall rules (e.g. UFW/iptables) to restrict inbound and outbound traffic to explicitly authorised ports and addresses only.

7. Deploy Monitoring & Intrusion Detection

Install an IDS/IPS solution (e.g. Fail2Ban, OSSEC, Wazuh) to detect and automatically respond to brute-force attempts and suspicious behaviour.

5. Evidence and Justification

5.1 Commands Executed

Purpose	Command
User enumeration	<code>cat /etc/passwd grep bash</code>
FTP service status	<code>systemctl status vsftpd</code>
Process inspection	<code>ps aux grep hacker</code>
Login history review	<code>last</code>
Account removal	<code>sudo userdel -r hacker</code>
Service stop	<code>systemctl stop vsftpd</code>
Service disable	<code>systemctl disable vsftpd</code>

5.2 Python-Based Validation

A Python one-liner was used to independently verify that no bash-enabled accounts remained after remediation:

```
python3 -c 'f=open("/etc/passwd"); [print(line.strip()) for line in f if "bash" in line]'
```

Finding	Result
hacker account present in /etc/passwd	✗ Not found — successfully removed
Other bash-enabled accounts	✓ Only legitimate system accounts remain
Automated verification method	Python script confirmed remediation success

System restored to secure state ✓

CONFIDENTIAL — Internal Use Only

Final Technical Report